

RISK TREATMENT PLAN

Acme Financial Services

Document Owner: Governance, Risk, and Compliance (GRC) Team

Approved By: Chief Information Security Officer

Document ID: RTP-001

Version: 1.0

Effective Date: June 2026

Review Frequency: Annual

Classification: Internal Use

Prepared by: Vearnell Israel

DOCUMENT CONTROL

Document Information	Details
Document Name	Risk Treatment Plan
Document ID	RTP-001
Version	1.0
Document Owner	Governance, Risk, and Compliance (GRC) Team
Classification	Internal Use
Effective Date	June 2026
Review Frequency	Annual
Approval Authority	Executive Leadership Team
Framework Alignment	NIST CSF 2.0, ISO 27001
Next Review Date	June 2027

REVISION HISTORY

Version	Date	Description	Author
1.0	June 2026	Initial Release	Vearnell Israel

1. PURPOSE

The purpose of this Risk Treatment Plan is to establish a structured approach for managing information security risks identified through the enterprise risk assessment process. Acme Financial Services utilizes risk treatment activities to reduce, transfer, avoid, or formally accept risks that may affect the confidentiality, integrity, and availability of information assets.

2. SCOPE

This plan applies to information systems, cloud environments, third-party service providers, databases, networks, employees, contractors, and vendors supporting Acme Financial Services operations. The plan applies to risks identified through enterprise risk assessments, risk registers, vulnerability assessments, audits, incidents, and management reviews.

3. RISK TREATMENT METHODOLOGY

Acme Financial Services evaluates identified risks using likelihood and impact scoring methodologies. Risk treatment activities are prioritized based on risk ratings, business objectives, and the organization's risk appetite.

Risk treatment options include:

- Mitigate
- Transfer
- Accept
- Avoid

High- and Critical-risk areas shall receive priority treatment and management oversight.

4. TREATMENT STRATEGIES

4.1 Mitigate

Risk mitigation reduces the likelihood or impact of threats by implementing administrative, technical, and physical safeguards.

Examples include:

- Multi-factor authentication
- Security awareness training
- Encryption
- Configuration management
- Continuous monitoring
- Vulnerability management

4.2 Transfer

Risk transfer shifts financial or operational responsibility to another entity through cyber insurance, vendor agreements, or contractual obligations.

4.3 Accept

Risk acceptance may be appropriate when residual risk remains within organizational risk tolerance and is approved by authorized management.

4.4 Avoid

Risk avoidance eliminates activities or technologies that create unacceptable risk exposure.

5. RISK TREATMENT ACTIONS

Risk	Current Rating	Treatment Strategy	Planned Action	Owner	Target Date	Residual Risk
Phishing	Critical	Mitigate	Conduct quarterly phishing simulations and awareness training	IT Security Team	06/30/2026	Moderate
Unauthorized Access	High	Mitigate	Perform quarterly access reviews and enforce MFA	IT Security Team	07/15/2026	Moderate
Cloud Misconfiguration	Critical	Mitigate	Implement continuous configuration monitoring	Cloud Team	08/14/2026	Moderate
Device Theft	High	Mitigate	Enforce full disk encryption and MDM controls	IT Support Team	08/22/2026	Low
Vendor Breach	High	Transfer	Conduct vendor assessments and strengthen contractual control	GRC Team	09/15/2026	Moderate
Credential Theft	Critical	Mitigate	Strengthen conditional access and password controls	Network Infrastructure Team	09/28/2026	Moderate
Third-Party Integration Compromise	High	Mitigate	Review API integrations and third-party security controls	Application Support Team	10/15/2026	Moderate

6. ROLES AND RESPONSIBILITIES

Executive Leadership

Provides executive oversight of the enterprise risk management program. Reviews significant risks, approves risk acceptance decisions, allocates resources for risk treatment activities, and ensures alignment with business objectives.

Chief Information Security Officer (CISO)

Provides strategic direction for the information security program, approves the Risk Treatment Plan, oversees enterprise cybersecurity risk management, and reports risk posture to executive leadership.

GRC Team

Maintains the enterprise Risk Register, coordinates risk assessments, tracks remediation efforts, monitors compliance with organizational policies, and reports risk treatment progress to management.

IT Security Team

Implements and monitors technical security controls, conducts vulnerability assessments, manages identity and access controls, supports incident response activities, and validates remediation efforts.

Cloud Team

Maintains secure cloud configurations, implements cloud security controls, continuously monitors cloud environments, and remediates identified cloud security risks.

Network Infrastructure Team

Maintains secure network infrastructure, firewalls, VPN services, network segmentation, and secure remote access controls to protect enterprise communications.

IT Support Team

Implements endpoint security controls, deploys security updates, manages encryption and endpoint protection technologies, and supports remediation activities for end-user devices.

Application Support Team

Maintains secure business applications, supports third-party integrations, coordinates application security improvements, and ensures application controls remain effective throughout the system lifecycle.

System Owners

Maintain ownership of assigned business systems, ensure security controls remain effective, support remediation activities, and participate in periodic risk reviews.

Business Owners

Identify business risks associated with organizational assets, approve risk treatment decisions affecting business operations, and ensure remediation activities align with operational objectives.

7. MONITORING AND REPORTING

Risk treatment activities shall be reviewed quarterly and documented within the enterprise risk register. Progress shall be reported to executive leadership through periodic risk reporting and management reviews.

8. EXCEPTIONS

Exceptions to this plan require documented business justification and approval by executive leadership and the Chief Information Security Officer.

9. REVIEW AND APPROVAL

This Risk Treatment Plan shall be reviewed annually and updated when significant changes occur to business operations, regulatory requirements, technologies, or the threat landscape.

Approved By:

Chief Information Security Officer

Date: _____

Executive Leadership Team

Date: _____